

《信息系统安全》第十六讲

计算机犯罪取证技术概论

2024年1月1日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

Oracle 体系架构

- 客户端 & 服务器端
- 服务器包括instance和数据库
- 存储结构、内存结构、进程结构

Oracle 安全架构

- 用户管理
- 资源管理
- 数据的备份与恢复

这一讲要解决什么问题？



谁入侵了我的电脑？



技术

??

法律

怎样证明是他干的？



这一讲要解决什么问题？

针对计算机系统或网络的犯罪活动以及利用计算机和网络从事各种犯罪活动的人越来越多，由此造成的经济损失令人触目惊心，引发的社会问题也越来越突出。

遏制这种日益严重的计算机犯罪形势，就必须将犯罪分子绳之以法，以法律的威慑力量来减少计算机犯罪的发生。

这一讲要解决什么问题？

打击计算机犯罪必须找到充分、可靠、有说服力的证据

计算机在相关的犯罪案例中可以扮演黑客入侵的目标、作案的工具和犯罪信息的存储器这**3**种角色。

无论作为哪种角色，通常计算机（连同它的外设）中都会留下大量与犯罪有关的数据，进而可以依据有关科学与技术的原理与方法找到证明某个事实的证据。

因此，计算机和法学的交叉学科——计算机取证（computer forensics）受到了越来越多的关注。



计算机 犯罪

计算机犯罪概念（广义）

Computer related crime or computer aimed crime?

计算机犯罪——通常是指所有涉及计算机的犯罪。 如：

- 欧洲经济合作与发展组织的专家认为：“在自动数据处理过程中任何非法的、违反职业道德的、未经过批准的行为都是计算机犯罪。”
- 我国刑法学者有人认为：“凡是故意或过失不当使用计算机致使他人受损失或有受损失危险的行为,都是计算机犯罪。”

计算机犯罪概念（狭义）

计算机犯罪——通常是对计算机资产本身进行侵犯的犯罪。

例如：

- **瑞典的私人保密权法规定：“未经过批准建立和保存计算机私人文件，非法窃取电子数据处理记录或非法篡改、删除记录侵犯个人隐私的行为都是计算机犯罪。”**
- **我国有学者认为，“计算机犯罪是指利用计算机操作所实施的危害计算机信息系统（包括内存数据及程序）安全的犯罪行为”**

计算机犯罪概念（折衷）

计算机本身在计算机犯罪中以“犯罪工具”或“犯罪对象”的方式出现，这一概念注重的是计算机本身在犯罪中的作用。如：

- **德国学者施奈德认为：“计算机犯罪指的是利用电子数据处理设备作为作案工具的犯罪行为或者把数据处理设备当作作案对象的犯罪行为。”**
- **我国学者认为：“计算机犯罪是以计算机为工具或以计算机资产为对象的犯罪行为**

计算机犯罪的特点

犯罪形式的隐蔽性

计算机执行一项犯罪指令，长则几分钟，短则千分之一秒甚至更短，因此计算机犯罪往往是在瞬间发生，有些罪证只是几个字节的信息，大多数计算机犯罪的证据都可以从计算机信息系统中销毁或删除干净而不被发现，即使留下犯罪证据，也是一些不可直接阅读的电磁记录，很难查清和确认计算机犯罪人员具体在哪些部位和工作环节上做了手脚，它隐散性极强，作案时空不定，破坏性强，即使发现也很难进行侦查。根据美国商务部透露，100例计算机犯罪中仅有1例被发现，而发现的犯罪中只有70%被披露。

计算机犯罪黑数高

所谓黑数是指虽已经实际存在，但未被列入官方统计的计算机犯罪总和中的那部分犯罪数字。造成计算机犯罪黑数值高的原因主要有两个：一是由于计算机犯罪往往涉及到公民的隐私、公司企业的秘密乃至商业的信誉，受害者为维护自身的信誉并不乐意报案；二是司法机关对计算机犯罪惩治力度不大。由于我国司法机关普遍存在经费不足，无法与金融、国防等部门同步进行计算机管理工作，而且司法工作人员缺乏计算机专业知识，对计算机犯罪难于发现，不能适应计算机犯罪的侦查、起诉和审判等司法活动的需要。

计算机犯罪的特点

犯罪主体和手段的智能性

计算机犯罪的犯罪手段的技术性和专业化使得计算机犯罪具有极强的智能性。实施计算机犯罪，罪犯要掌握相当的计算机技术，需要对计算机技术具备较高专业知识并擅长实用操作技术，才能逃避安全防范系统的监控，掩盖犯罪行为。所以，计算机犯罪的犯罪主体许多是掌握了计算机技术和网络技术的专业人士。他们洞悉网络的缺陷与漏洞，运用丰富的电脑及网络技术，借助四通八达的网络，对网络系统及各种电子数据、资料等信息发动进攻，进行破坏。由于有高技术支撑，网上犯罪作案时间短，手段复杂隐蔽，许多犯罪行为的实施，**可在瞬间完成，而且往往不留痕迹**，给网上犯罪案件的侦破和审理带来了极大的困难。而且，随着计算机及网络信息安全技术的不断发展，犯罪分子的作案手段日益翻新，甚至一些原为计算机及网络技术和信息安全技术专家的职务人员也铤而走险，其作恶犯科所采用的手段则更趋专业化。

计算机犯罪的特点

复杂性

(1) 犯罪主体的复杂性

任何罪犯只要通过一台联网的计算机便可以在电脑的终端与整个网络合成一体，调阅、下载、发布各种信息，实施犯罪行为。而且由于网络的跨国性，罪犯完全可来自各个不同的民族、国家、地区，网络的“时空压缩性”的特点为犯罪集团或共同犯罪有提供了极大的便利。

(2) 犯罪对象的复杂性

计算机犯罪就是行为人利用网络所实施的侵害计算机信息系统和其它严重危害社会的行为。其犯罪对象也是越来越复杂和多样。有盗用、伪造客户网上支付帐户的犯罪；电子商务诈骗犯罪侵犯知识产权犯罪；非法侵入电子商务认证机构、金融机构计算机信息系统犯罪，破坏电子商务计算机信息系统犯罪，恶意攻击电子商务计算机信息系统犯罪；虚假认证犯罪；网络色情、网络赌博、洗钱、盗窃银行、操纵股市等。

计算机犯罪的特点

匿名性

罪犯在接受网络中的文字或图像信息的过程是不需要任何登记，完全匿名，因而对其实施的犯罪行为也就很难控制。罪犯可以通过反复匿名登录，几经周折，最后直奔犯罪目标，而作为对计算机犯罪的侦查，就得按部就班地调查取证，等到接近犯罪的目标时，犯罪分子早已逃之夭夭了。

计算机犯罪的特点

跨国性

网络冲破了地域限制，计算机犯罪呈国际化趋势。因特网络具有“时空压缩化”的特点，当各式各样的信息通过因特网络传送时，国界和地理距离的暂时消失就是空间压缩的具体表现。这为犯罪分了跨地域、跨国界作案提供了可能。犯罪分子只要拥有一台联网的终端机，就可以通过因特网到网络上任何一个站点实施犯罪活动。而且，可以甲地作案，通过中间结点，使其他联网地受害。由于这种跨国界、跨地区的作案隐蔽性强、不易侦破，危害也就更大。

计算机犯罪的特点

损失大，对象广泛，发展迅速，涉及面广

据美国联邦调查局统计测算，一起刑事案件的平均损失仅为2000美元，而一起计算机犯罪案件的平均损失高达50万美元。据计算机安全专家估算，近年因计算机犯罪给总部在美国的公司带来的损失为2500亿美元，英、德的年损失也达几十亿美元。

我国从1986年开始每年出现至少几起或几十起计算机犯罪，到1993年一年就发生了上百起，近几年利用计算机犯罪的案件以每年30%的速度递增，其中金融行业发案比例占61%，平均每起金额都在几十万元以上，单起犯罪案件的最大金额高达1400余万元，每年造成的直接经济损失近亿元。

计算机犯罪的特点

低龄化和内部人员多

我国对某地的金融犯罪情况的调查，犯罪的年龄在35岁以下的人占整个犯罪人数的比例：1989年是69.9%，1990年是73.2%，1991年是75.8%。其中年龄最小的只有18岁。

此外，在计算机犯罪中犯罪主体中内部人员也占有相当的比例。据有关统计，计算机犯罪的犯罪主体集中为金融、证券业的“白领阶层”，身为银行或证券公司职员而犯罪的占78%，并且绝大多数为单位内部的计算机操作管理人员；从年龄和文化程度看，集中表现为具有一定专业技术知识、能独立工作的大、中专文化程度的年轻人，这类人员占83%，案发时最大年龄为34岁。

计算机犯罪的类型举例

非法侵入计算机信息系统罪

《刑法》第285条规定，违反国家规定，侵入国有事务、国防建设、尖端科学技术领域的计算机信息系统的，处三年以下有期徒刑或者拘役。

计算机犯罪的类型举例

破坏计算机信息系统罪（《刑法》第286条）

- ❖ 故意对计算机信息系统功能进行删除、修改、增加、干扰，造成计算机信息系统不能正常运行，**后果严重的行为**；
- ❖ 故意对计算机信息系统中存储处理或者传输的数据和应用程序进行删除、修改、增加的操作，**后果严重的行为**；
- ❖ 故意制作、传播计算机病毒等破坏性程序，影响计算机系统正常运行，**后果严重的行为**。

计算机信息系统具有感染性、潜伏性、可触发性、破坏性。破坏计算机信息系统的动机各异，但无论行为人破坏计算机信息系统的动机如何，都不影响本罪的成立。即只要行为人故意破坏计算机信息系统，影响计算机系统正常运行，后果严重的，就构成本罪。

计算机犯罪的类型举例

利用计算机实施金融诈骗、盗窃、贪污、挪用公款、窃取国家秘密罪（《刑法》第287条）

利用计算机实施盗窃的行为纳入盗窃罪定罪处罚的范围，从而使盗窃罪更具信息时代的特征。

Ex: 盗窃电子资金

不法分子往往利用电子资金过户系统，例如定点销售系统（POSS）、自动存取款机（ATM）自动化票据交换所（ACHS）、电子身份证系统等提供的便利，使用计算机技术通过网络修改电子资金账目，窃取电子资金。

计算机犯罪的类型举例

数据欺骗

非法篡改输入/输出数据获取个人利益，是最普通最常见的计算机犯罪活动。发生在金融系统的此种计算机犯罪多为内外勾结，串通作案，由内部人员修改数据，外部人员提取钱款。

计算机犯罪的类型举例

意大利香肠术

侵吞存款利息余额，积少成多的一种作案手段，是金融系统计算机犯罪的典型类型。这种方法很像偷吃香肠一样，每次偷吃一小片并不引起人们的注意，但是日积月累的数目也是相当可观。

此类案件在国内外均有发现，因为只有修改计算机程序才能达到其犯罪目的，故多为直接接触程序的工作人员所为。目前国内多数为局域网管理银行帐目而产生此类犯罪。因此，要警惕采用此手段作案的罪犯。



计算机 取证



计算机取证（电子取证）定义



计算机取证专业资深人士Judd Robbins:

计算机取证不过是简单地将计算机调查和分析技术应用于对潜在的、有法律效力的证据的确定与获取上。

- Deposition and trial experience
 - Testimony in State and Federal courts
 - Balanced caseload of 50-50% plaintiff and defense
 - Specializing in copyright, patent & trade secret matters
 - More than 100 cases since 1986 as an expert witness/consultant
 - Professional Clientele in both the United States and the United Kingdom
 - Decades of experience as both a software and hardware computer expert
- Call Judd at 1-541-512-2508 (PST) today to discuss your needs!**

International Case Experience since 1986
Best Selling Author of 30 Computer Books
and more than 25 Training Videos
Seminar Design/Presentation since 1978
A.B. Physics (Bowdoin College)
M.A. Computer Science (U.C. Berkeley)
M.S. Information Science (U. of Michigan)
Featured as Computer Expert Witness on MSNBC, Court TV, & Tech TV



计算机取证（电子取证）定义

专业的计算机紧急事件响应和计算机取证咨询公司：

计算机取证包括了对以磁介质编码信息方式存储的计算机证据的保护、确认、提取和归档。



美国NTI公司



计算机取证（电子取证）定义

一篇综述文章给出了如下的定义：

计算机取证是使用软件和工具，按照一些预先定义的程序全面地检查计算机系统，以提取和保护有关计算机犯罪的证据。



计算机取证（电子取证）定义

综合：

计算机取证是指对能够为法庭接受的、足够可靠和有说服性的，存在于计算机和相关外设中的计算机证据的确认、保护、提取和归档的过程。

计算机和法学的交叉学科



司法鉴定

何谓司法鉴定？

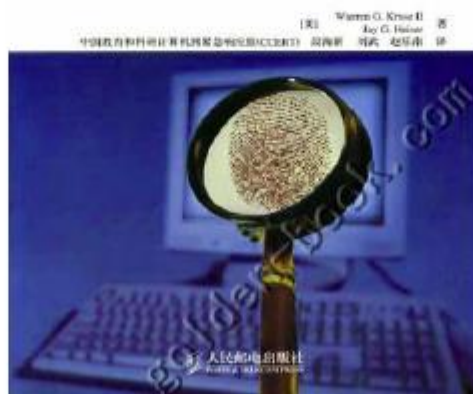
一种解释认为：“司法鉴定是鉴定人运用科学技术或者专门知识对涉及诉讼的专门性问题进行检验、鉴别和判断并提供鉴定结论的活动”，强调的是鉴定人向委托人提供鉴定结论的一种服务。

另一种解释将司法鉴定界定为：“在诉讼过程中，为查明案件事实，人民法院依据职权，或者应当事人及其他诉讼参与人的申请，指派或委托具有专门知识的人，对专门性问题进行检验、鉴别和评定的活动”，强调这种鉴定是由审判法庭启动实施的，具有司法的中立性。

计算机司法鉴定的检验、鉴别、判断等属于计算机取证



计算机取证相关的图书





潜在证据



界定取证的范围

为了确定后续的具体行动，应当对计算机取证的现场范围进行彻底的评估

首先依据搜查令或其他授权，根据案件的细节、硬件和软件系统的性质、潜在证据以及整个获取证据现场的环境来确定哪些证据将要进行重点检查。



潜在证据



复印机



路由器



数码相机



计算机

证据通常都是在可以存储数据的硬件驱动器、存储设备或媒体中发现的。



交换机



打印机

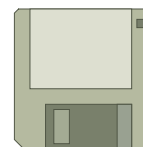
安全事件



传真机



扫描仪



移动存储



手持设备
(PDA等)



计算机系统中的潜在证据：内存

内存dump工具

- Dumpit: <http://www.moonsols.com/wp-content/uploads/downloads/2011/07/DumpIt.zip>
- 内存文件与内存大小接近或者稍微大一点，raw格式最好

```
E:\NDASH\DumpIt.exe
DumpIt - v1.3.2.20110401 - One click memory memory dumper
Copyright (c) 2007 - 2011, Matthieu Suiche <http://www.msuiche.net>
Copyright (c) 2010 - 2011, MoonSols <http://www.moonsols.com>

Address space size:      19579011072 bytes ( 18672 Mb)
Free space size:        146235064320 bytes ( 139460 Mb)

* Destination = \\E:\NDASH\NDASH-20201128-154620.raw

--> Are you sure you want to continue? [y/n] _
```

镜像名!

确认提示! "yes/no"



计算机系统中的潜在证据：内存

- 分析内存文件

- volatility imageinfo -f xp.raw #文件信息, 关注profile
- volatility hivelist -f XP.raw --profile=WinXPSP3x86 #数据库文件
- volatility -f XP.raw --profile=WinXPSP3x86 hivedump -o 0xe124f8a8
- # 按虚内存地址查看注册表内容
- volatility -f XP.raw --profile=WinXPSP3x86 printkey -K "SAM\Domains\Account\Users\Names" # 用户账号
- volatility -f xp.raw --profile=WinXPSP3x86 printkey -K "SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" #最后登陆的用户
- volatility -f XP.raw --profile=WinXPSP3x86 userassist #正在运行的程序、运行过多少次、最后一次运行时间等

Foremost（美国政府开发）：

从内存中恢复文档图片，支持raw/dd/iso/vmem等格式

```
foremost -t jpeg,gif,png,doc -i 7.raw
```

- 内存取证发现恶意软件

- XP：建立 meterpreter session 后 dump 内存分析
- volatility -f xp.raw --profile=WinXPSP3x86 pstree
- volatility connscan # 网络连接
- volatility getsids -p 111,222 # SID
- volatility dlllist -p 111,222 # 数量
- volatility malfind -p 111,222 -D test # 检查结果查毒



从内存中抓取明文密码

- `procdump -ma lsass.exe lsass.dmp`
- Mimikatz
- `sekurlsa::minidump lsass.dmp`
- `sekurlsa::logonPasswords`

Volatility的mimikatz插件

<https://github.com/sans-dfir/sift-files/blob/master/volatility/mimikatz.py>



计算机系统中的潜在证据：文件

用户建立的
文件

用户保护的
文件

其它数据

操作系统建立的
文件



从文件中提取证据

→ Autopsy

- 非常流行的硬盘镜像分析工具
- Webserver+客户端架构

→ Extundelet

- 适用于ext3/ext4文件系统的反删除工具
- Extundelete [device-file] --restore-file [restore location]



计算机系统中的潜在证据：**用户建立的文件**

用户建立的文件归纳

- 地址簿
- Internet的历史收藏夹
- 电子邮件
- 数据库文件
- 视频或音频文件
- 电子表格
- 图片
- 文本文件
- 日程表

用户建立的文件可能包含犯罪活动的重要信息。例如，数据库文件可以证明罪犯的联系活动，存储或移动过的图片可能成为恋童癖者犯罪的证据，罪犯之间的通信记录例如电子邮件、聊天记录也肯定成为证据。在贩毒案的调查中毒品的明细列表常常可以在电子表格中发现。



计算机系统中的潜在证据：用户保护的文件

嫌疑人很可能将证据以各种方式隐藏以来。

- 例如，嫌疑人常常将对他们很重要的文件翻译成密文或对文件进行密码保护。他们也可能将重要的数据隐藏在某个磁盘下或将重要文件放在一个与内容无关的文件夹下。现对用户保护的文件归纳如下：
 - 压缩文件、歧义名称文件、加密文件、密码保护文件、隐藏文件、数据隐藏

值得注意

一些文件的属性也要列入调查取证的范围。
例如，文件的建立、修改、移动、删除时间，文件的所有者，访问权限等等。有时仅仅开启计算机就可能改变某些文件信息。



计算机系统中的潜在证据：操作系统建立的文件

证据常常可以在由操作系统运行时建立的文件中，大多数情况下用户并没有认识到这一点。密码、Internet活动记录、临时文件、备份文件等常常可以通过恢复这些文件得到。

- 备份文件、日志文件、配置文件
- 打印机缓存文件、Cookies、交换文件
- 隐藏文件、系统文件、历史记录
- 临时文件



计算机系统上的潜在证据：其他数据

- 磁盘坏簇、其它分区、保留区域
- 删除文件、软件注册信息、未分区空间
- 自由空间、隐藏分区、系统区

以上是基于操作系统的数据，主要针对的是计算机的硬盘。



数码相机中的潜在证据

- 数码相机获取的视频、音频或照片都是数字格式的，可以很容易的上传到计算机中进行浏览和编辑。潜在证据如下：
 - 图片
 - 时间和日期戳
 - 视频文件
 - 音频文件



移动终端中的潜在证据

- 移动终端基本上已经实现了普通台式机的功能
- 值得注意的是由于终端基本上都是电池供电，存储的信息很有可能由于电池的电量耗尽而丢失。所以要准备为这些设备提供持续的电源。
 - 移动终端主要关注以下信息：
 - 地址簿
 - 密码
 - 日程表
 - 电话本
 - 文档
 - 短消息
 - 语音信箱
 - 电子邮件



CELLDEK:便携式手机取证箱

CELLDEK是一款是Logicube 公司的便携式手机取证箱，支持国际上大部分主流品牌的手机和PDA 信息的提取。

CELLDEK 是一款高级的手机数据提取设备，内嵌一台笔记本电脑，通过触摸屏显示的手机品牌、型号、尺寸或图片快速识别和确认嫌疑手机。

大约在5分钟左右的时间里提取出手机里的信息。





手机信号屏蔽箱

RF Enclosure屏蔽箱能够对目标手机进行信号屏蔽，防止对手机进行分析、查看的办案过程中受到外界手机信号的干扰。





移动存储设备中的潜在证据

- 移动硬盘、存储卡、记忆棒这些设备断电后仍然可以保存里面的数据。移动硬盘和普通的硬盘原理是一样的，只是加强了对硬盘的物理保护功能。存储卡、记忆棒采用的是闪存。存储卡大量地在数码相机、智能手机、PDA上作为扩展存储器。
- 这些存储卡的上已经删除的信息也可以通过恢复工具对其恢复。针对这些存储设备中的潜在证据，可以将其连接到计算机，在操作系统中像处理硬盘中的数据一样来处理。



网络部件（包括网卡、路由器、交换机、集线器等）中的潜在证据

- 这些设备的出现预示着计算机可能接入网络中。
- 值得注意的是：网卡、路由器等网络设备很可能是无线的。这点在检查笔记本电脑时要特别注意。这些设备本身便可能是潜在证据。此外，网卡中的MAC地址、路由器的配置文件都可能成为潜在证据。

非手机取证：

**路由器取证
这么简单
你知道方法吗？**



1. 将路由器打开，拆取存储芯片；
2. 采用物理提取的方式进行镜像；
3. 打开镜像的十六进制文件进行解析；
4. 分析服务器IP地址、个人登录的账号和密码等信息。



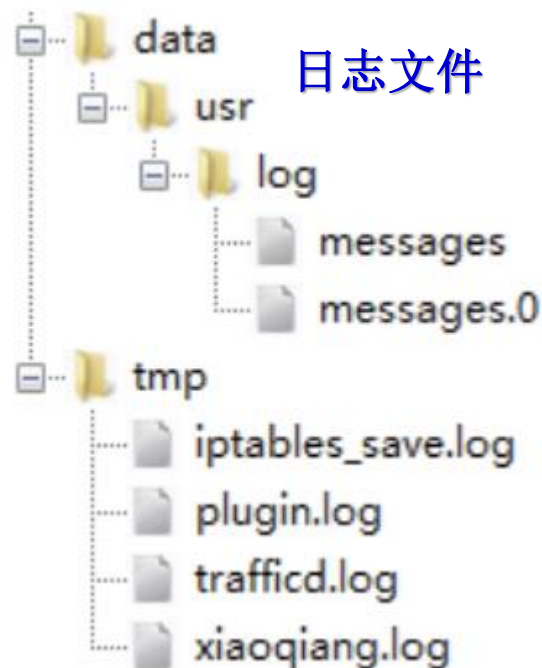


智能路由器数据取证方法

智能路由器通常是指具有独立操作系统，可以由用户进行智能化管理的网络路由器。智能路由器逐渐成为电子取证工作中一项新的挑战。

智能路由器有别于传统路由器，其提供了丰富的扩展应用功能，内置离线下载、内网检测、视频加速等功能，用户可以根据需求下载扩展应用，比如 PT 下载、远程下载、广告拦截、备份助手等，用户可根据自身的需求，个性化定义路由器，也就是智能路由器包含了更多的个人信息记录。

内部存储的用户数据可能为办案人员提供重要线索，是未来电子物证检验工作中必不可少的一个环节。



计超豪，邱殿聪，王即墨等. 智能路由器数据取证方法[J]. 刑事技术, 2019, 44(5): 447-450.



打印机、复印机、扫描仪和传真机中的潜在证据



打印机、复印机、扫描仪这些设备一般都连接到计算机，并受计算机控制。这些设备一般都会保存使用日志、时间和日期信息。

通常都具有缓冲，可以存储来自计算机的任务。如果这些设备接入到网络中，这些设备还将存储网络身份信息。另外可通过这些设备本身的特征来区分证据是否来自这些设备。

数码复印机会把很多重要数据以图片格式保存在硬盘中，这些数据包括但不限于内部文档、合同、技术资料、方案图纸、涉密文件以及其他需要复印打印的涉密信息。这些保存在数码复印机硬盘中的数据就是我们保密检查以及复印机取证的核心内容。

数码复印机、多功能一体机复合机、打印复印一体机标配硬盘或者存储卡（存储容量在40G-1000G左右）。根据国家保密局、国家安全部、科研院所等涉密单位调研发现，数码复印机等常用办公设备的带有数据存储功能的硬盘，如果没有妥善处理的情况下，存在重大的敏感信息泄密风险。



数码复印机硬盘数据信息保密检查取证系统

达思科技对七大品牌（佳能、富士施乐、理光、夏普、东芝，柯尼卡美能达、京瓷）数百款型号数码复印机，研制数码复印机数据信息保密检查取证系统，并通过国家保密科技测评中心课题专项测评（国保测2016C04554），同时通过了国家保密局科技司组织的项目验收专家

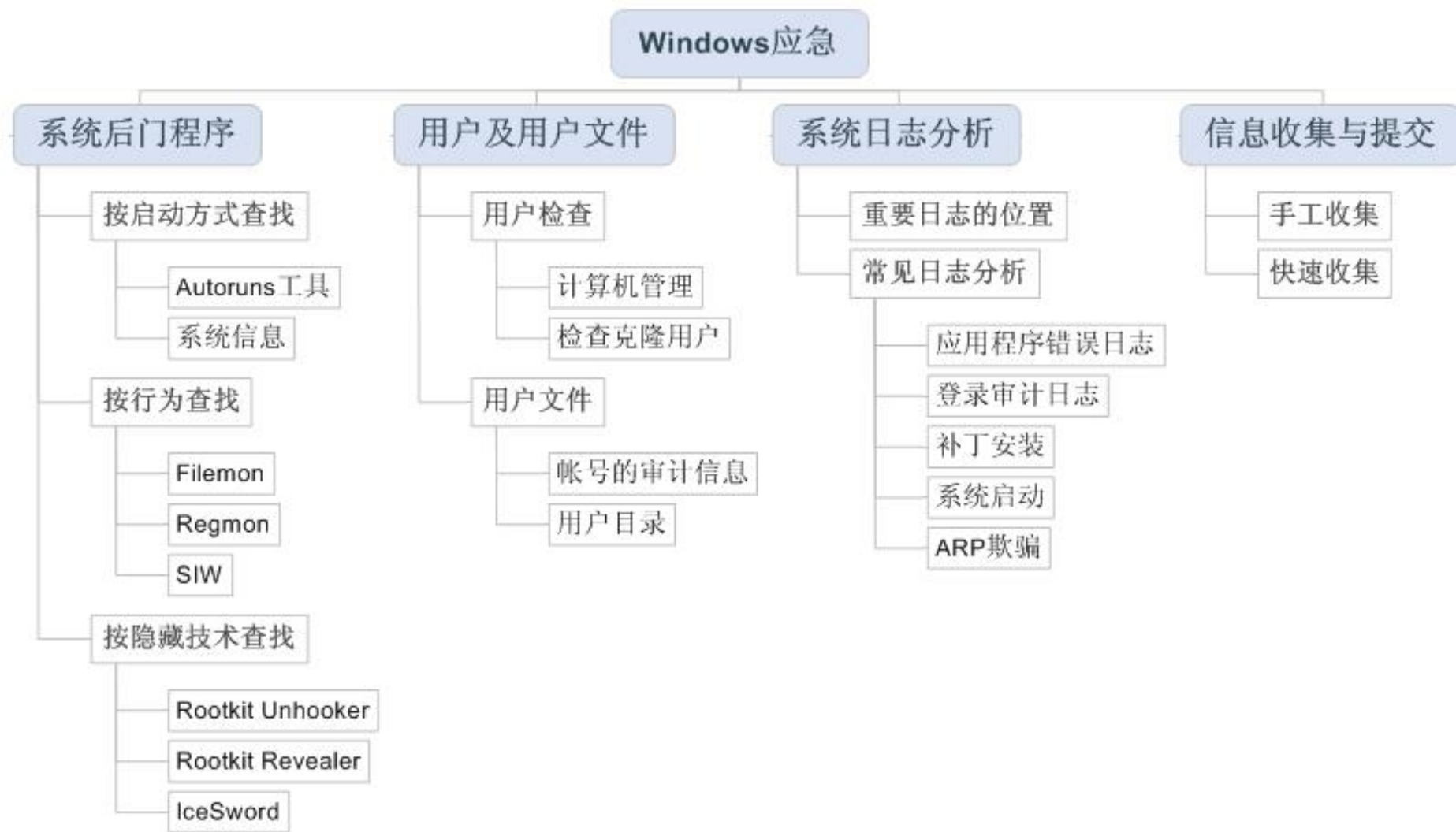
达思数码复印机硬盘数据保密检查取证系统技术：

序号	检查项目	在线检查	深度检查
1	文件系统解析	支持	支持
2	数据解密	支持	支持
3	图片转码解析	支持	支持
4	图片文字转文本文字（OCR）	支持	支持
5	敏感关键词检索	支持	支持
6	删除的数据恢复	不支持	支持
7	扫描、复印、打印、传真	支持	支持
8	生成检查报告	支持	支持
9	镜像功能	支持	支持
10	操作日志解析	支持	支持
11	设备信息管理	支持	支持
12	违规使用鉴定	支持	支持
13	复印机硬盘镜像	不支持	支持



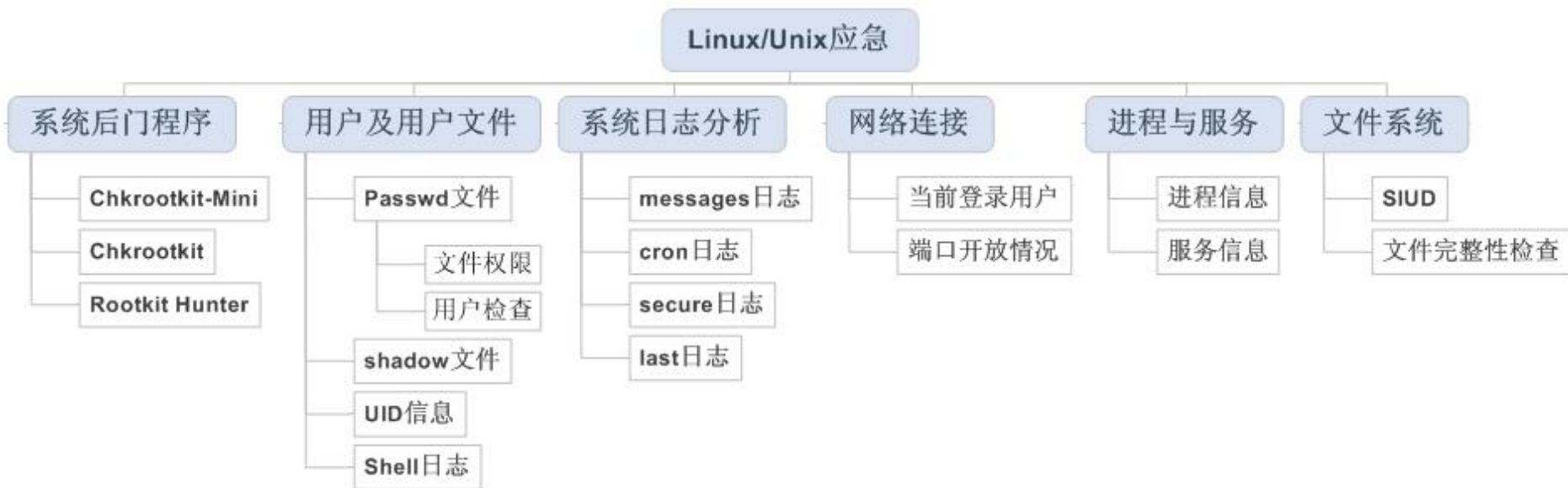


Windows系统安全事件处理



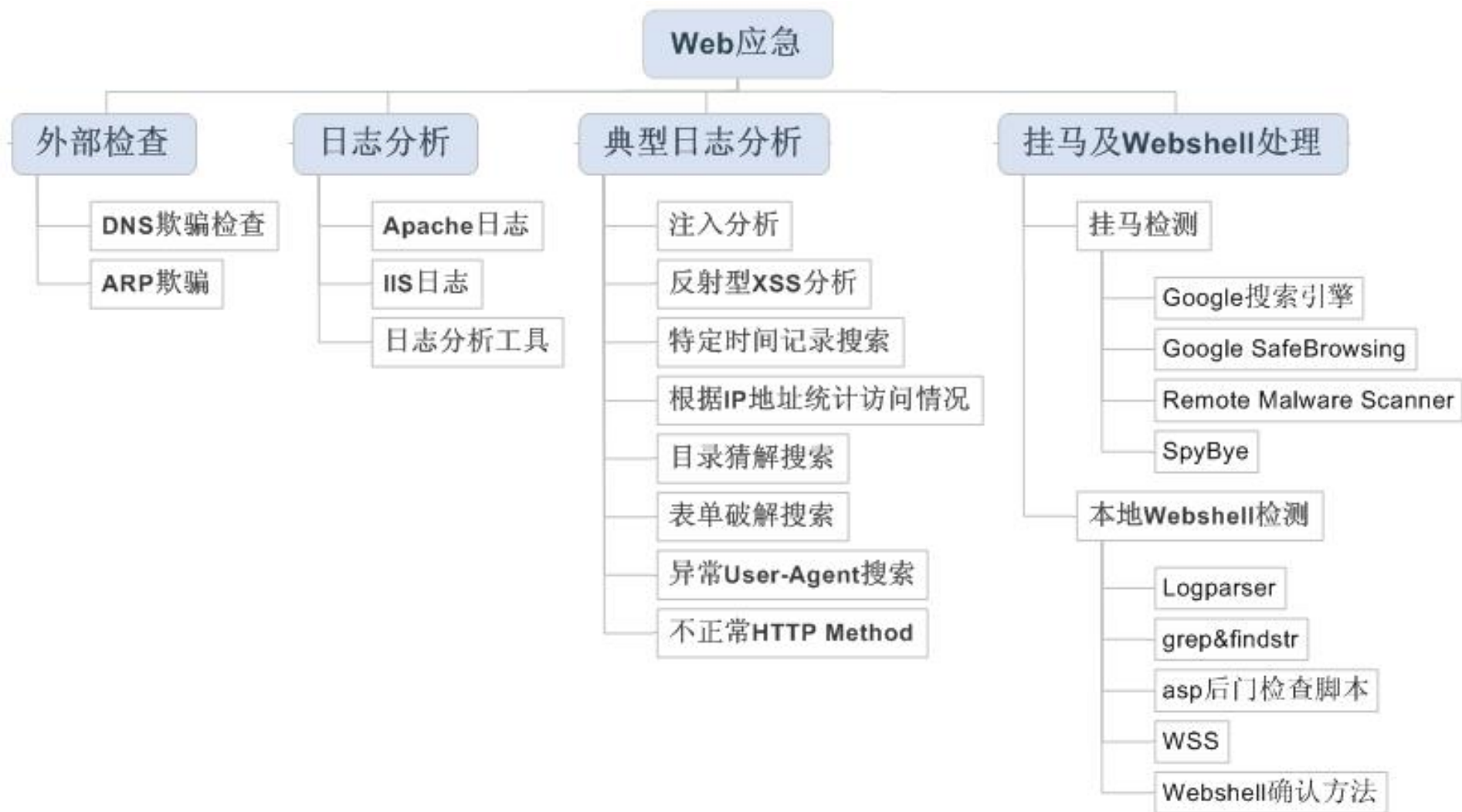


Linux/ Unix系统安全事件处理





Web系统安全事件处理





拒绝服务攻击事件（DDoS）处理：SYN Flood攻击

此种攻击经过抓包分析可以看到，大量的SYN请求发向目标地址，而SYN包的源地址为大量的随机生成的虚假地址。

22	0.200263	192.168.1.51	10.10.10.13	TCP	46644	> netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
23	0.210279	192.168.1.20	10.10.10.13	TCP	54611	> netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
24	0.220299	192.168.1.58	10.10.10.13	TCP	31101	> netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
25	0.230305	192.168.1.93	10.10.10.13	TCP	39174	> netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
26	0.240320	192.168.1.74	10.10.10.13	TCP	7739	> netbios-ssn [SYN] Seq=0 Len=0 MSS=1460

在目标主机上使用netstat -an命令可以看到大量SYN连接，处于syn_received状态

TCP	10.10.10.13:139	192.168.1.95:12295	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:43613	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:45626	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:51567	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:16653	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:24637	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:46674	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:53784	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:63246	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.97:17252	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.97:19265	SYN_RECEIVED

如今的黑洞ADS已经具备单机240G、单集群上T的清洗能力。

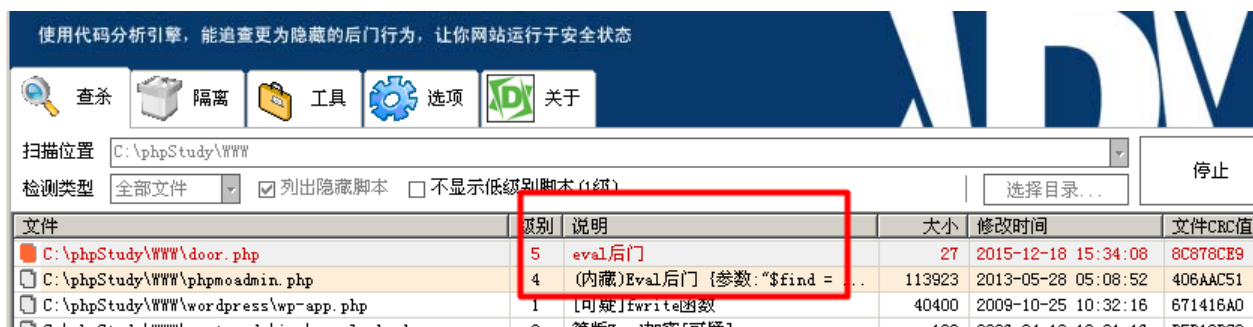
使用黑洞或其他专用防护设备来进行防护，黑洞默认参数下就可以达到比较好的效果。



案例分析

某公司网站被恶意篡改，现需要进行入侵分析与调查取证追踪。

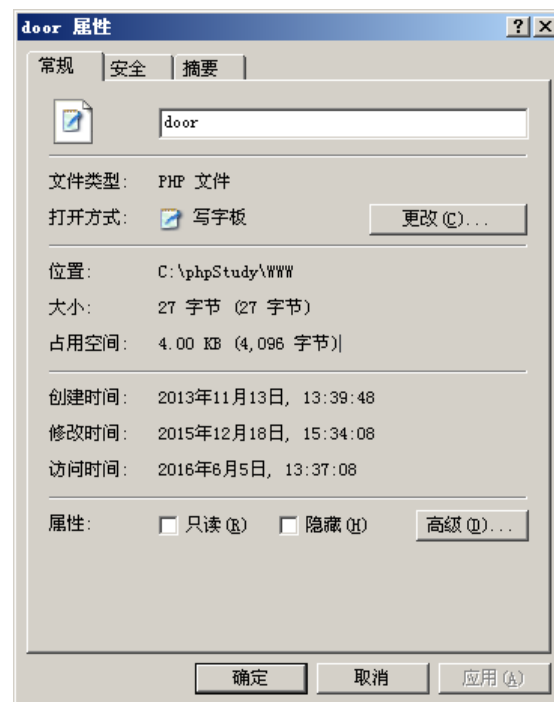
在初步了解完情况以后，对Web目录进行可疑文件扫描，发现可疑文件，且修改时间较新





案例分析

通过修改时间判断系统遭到攻击的时间





案例分析

然后分析中间件日志，搜索door，发现有一条日志比较可疑

攻击者IP: 192.168.40.137

经进一步分析确定攻击者是利用Apache解析漏洞对站点实施的攻击

```
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/myapp.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/footer.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/info_nav.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/space_set.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/userpay.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/header.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/info_base.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /images/door.php.xxjpg HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/info_tags.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/user_home.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/info_link.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/info_face.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/space_index.htm HTTP/1.1" 200 1024
192.168.40.137 - - [18/Dec/2015:23:08:06 -0800] "GET /phpwind/u/themes/default/space_info.htm HTTP/1.1" 200 1024
```



潜在证据：小结

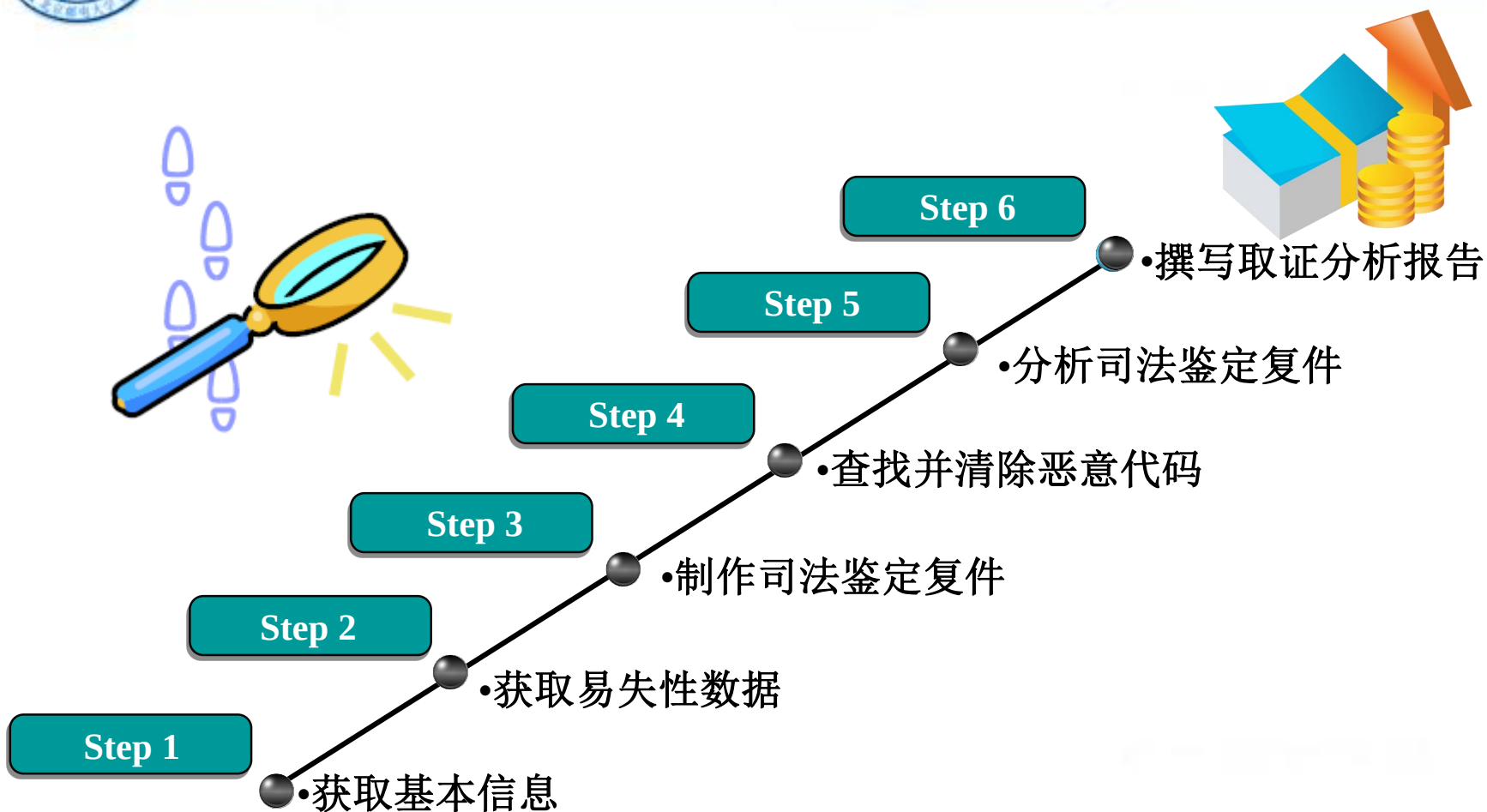
- 以上尽可能全面地列出了在现场可能发现的潜在证据，在某一案件中不一定会出现以上所有的设备。
- 但是计算机调查人员进入现场后应该首先留意以上设备，这是数字犯罪的证据收集中的常见设备。
- 由于技术的进步可能会在犯罪现场中出现更新的设备。这就要求计算机调查人员在平时要多了解一些新的数字设备，熟悉这些数字设备的功能。这样会提高在犯罪现场识别潜在证据的能力。



计算机证据 收集过程



取证的基本流程





取证的原则

1

取证过程中不能对目标设备有任何改动，读取硬盘数据必须用“只读锁”

2

所有提取的文件都要经过签名，保证不被篡改

3

保存证据的硬盘每次使用前都要“洗盘”——清零操作（Erases）

4

尽可能优先提取易失性数据——内存、网络数据包等等

5

分析证据的工作应该在工作副本（对目标硬盘逐位、逐字节的镜像）上进行



计算机证据收集的过程

Step 1

记录被检查系统的硬件和软件配置，确认被检查系统所包含的硬件和软件。

Step 2

拆开被检查计算机，检查计算机的硬盘。

注意：在这个过程中要注意避免静电和强磁场

Step 3

确认将要收集的存储设备，这些存储设备既可能是内置的也可能是外置的，有的系统可能同时拥有这两种设备。

Step 4

记录内置存储设备和硬件配置，包括：

- 驱动情况（例如，品牌、型号、尺寸、跳线、硬件接口等）
- 内部部件（例如，声卡、显卡、网卡、视频采集卡等。）



计算机证据收集的过程

Step 5

通过受控制的引导程序恢复可疑系统的配置信息

Step 6

尽可能地将存储器从可疑计算机中拆卸下来，使用预先准备好的监测系统来进行证据的提取

还有一点要注意的是，检测系统中的存储器在用于提取证据以前必须是干净的。所谓干净是使用专用工具对存储器进行清除，除去曾经记录任何数据的痕迹。



OmniClone 5Xi 硬盘拷贝机

OmniClone 5Xi 硬盘拷贝机能够一次性复制五块目标硬盘，支持UDMA-5 传输速度，IDE、EIDE、UDMA和SATA硬盘的拷速度达到3.5G/min。同时具备了可视彩色信号灯用于清楚的显示设备的工作状况。





计算机证据的保存

对于所搜集到的证据，应进行有效可靠地保存

- 所谓证据的保存应该从保护和保存两个角度来看待：并不是单纯地将收集到的数据保存起来，还必须保护数据不被修改。在进行计算机取证的过程中要保证不能改变数据，不能引入病毒，不能使数据受到破坏。为了得到最好的数据分析效果，最重要的就是要确保收集到的数据的安全。
- 在计算机取证过程中，某些案件的侦破需要很长时间，在这段时间内，磁盘的映像将会被分析很多次，这就要求找出一个合适的媒体来存放磁盘映像。



证据保存

计算机证据可能被改变或被篡改而没有明显痕迹。

- 初始的拷贝应该保存在一个非常安全的地点。但是有时候受害人会对带走他的计算机的行为进行起诉，如果这台计算机用于商业系统。这会导致受害人遭到更大的经济损失。
- 取证专家**Jim Bates**认为，两份完整的取证拷贝将可以解决这种问题。取证调查可以在其中一份拷贝上进行而另一份拷贝则保存在安全的地点。当怀疑证据的真伪的时候则可以调出另外一份证据作对比。
- 证据可能需要长期保存，此时应当选择可靠存储介质进行归档保存。



证据的完整性保护

从安全的角度考虑，在各个环节都需要验证数据和原数据是否一致。

- 例如在进行磁盘映像以前先记录下初始证据中的校验和，磁盘映像后对拷贝再进行一次计算得出校验和，比较两次的结果就可以确保两次的数据是否完全一致。
- 目前的校验值采用CRC或MD5 算法来确保证据的一致性。
- 另外取证专业磁盘映像工具可以产生映像日志，日志中将记录磁盘的所有参数、接口状况、数据包的校验和、目前时间和分析人员的姓名。



计算机取证 的工具和方法



传统的取证工具

auditpol

确定系统的审核策略

reg

转储**Windows**系统注册表中的特定信息（键）

regdump

以文本文件格式转储注册表

pwdump6

转储**SAM**数据库，可破解密码

NTLast

监控成功和失败的系统登录

Sfind

侦测隐藏在**NTFS**文件流中的文件

Afind

扫描文件系统找出在某时段内被访问过的文件

Dumpel

转储**Windows**系统的事件日志





EnCase 取证分析软件

知道至少两个取证工具即可

- ❑ 美国Guidance公司产品
- ❑ EnCase是全世界法律实施和IT安全专业人士使用的排名第一位的计算机犯罪取证软件
- ❑ 成为全世界计算机犯罪调查取证的标准和通用平台
- ❑ 有效保证电子证据的完整性、可信性、准确性



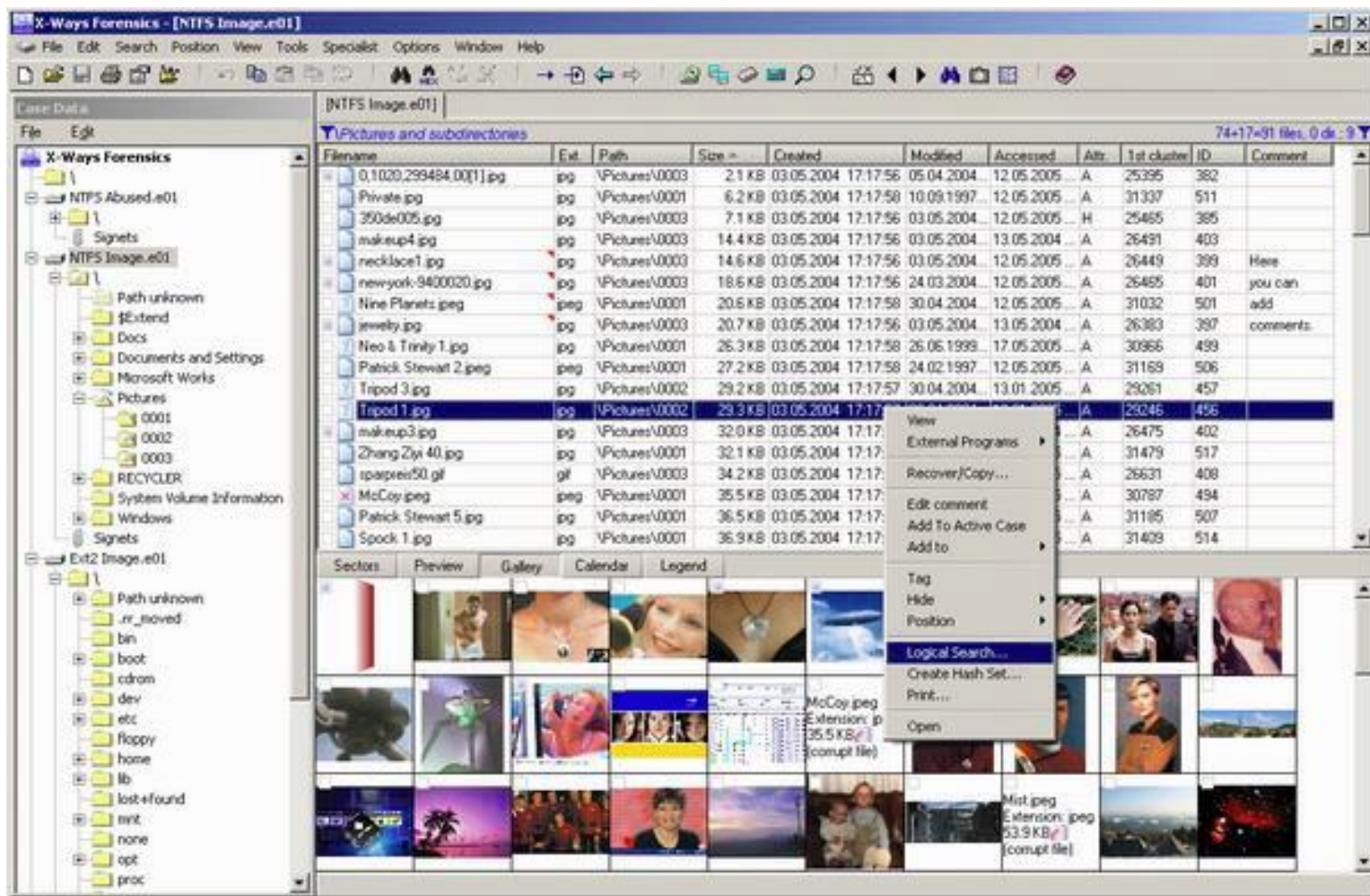


X-Ways Forensics

- 德国X-Ways公司最著名的计算机取证工具
- 为计算机法证人员提供的一个功能强大的、综合的取证、分析环境
- 包含WinHex软件的所有基本功能，并增加了很多特有功能，也被称为WinHex法证版



X-Ways Forensics





FTK 司法分析软件

- FTK (Forensic Toolkit) 是世界上公认的计算机取证调查的必备工具，功能强大、界面友好、使用简单
- 集成解决方案：
 - 创建镜像、查看注册表、破解加密文件、调查分析案件和生成报告一体化
 - **恢复超过 80 多种加密文件类型的密码**
 - **集成 Oracle 数据库和增强搜索功能**
 - 强大的处理能力和速度
 - 直观界面和强大功能





F-Response在线网络取证工具

- 在开机状态下直接取证，避免丢失易失性数据
- 在局域网范围内远程取证，支持VPN连接
- 可靠的加密连接、只读方式
- 可以与X-Ways Forensics、Smart、MacForensicsLab、FinalForensics、Intella等取证软件全面配合
- 对Windows、MacOS、Linux三种操作系统都可成功实现在线分析和取证
- 分为FK法证版、CE调查版、EE企业版





F-Response在线网络取证工具





硬件取证工具

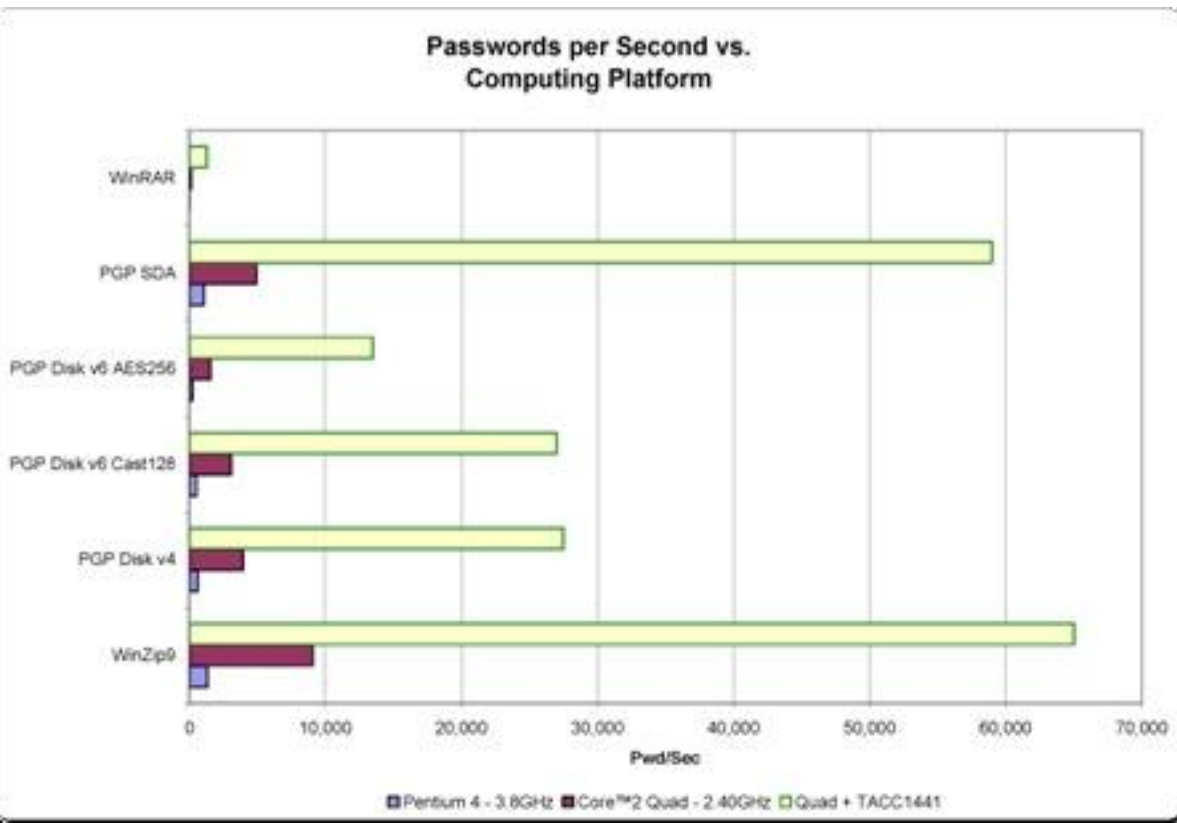




TACC1441硬件加速器

TACC1441支持OFFICE 2007密码破译硬件加速器——破解AES 128位加密文档的关键。

TACC1441硬件加速器能够在敏感数据侦察和智能操作时为用户节省宝贵时间。





网络资源

FIRST	www.first.org
HTCIA	www.htcia.org
CERT	www.cert.org
ISSA	www.issa.org
SANS	www.sans.org
InfraGard	www.infragard.net
Foundstone	www.foundstone.com



InfraGard®



Summary of The Class



□ 计算机犯罪&计算机取证的定义

Judd Robbins、专业取证咨询公司、论文

□ 计算机取证的范围界定及潜在证据

搜查令、案件性质、设备性质

计算机、数码相机、移动存储、PDA、网络设备

□ 计算机取证过程

证据保存、证据完整性保护

□ 计算机取证工具

软件：EnCase、X-way、FTK

硬件：硬盘拷贝机、手机信号屏蔽箱、硬件加速器